

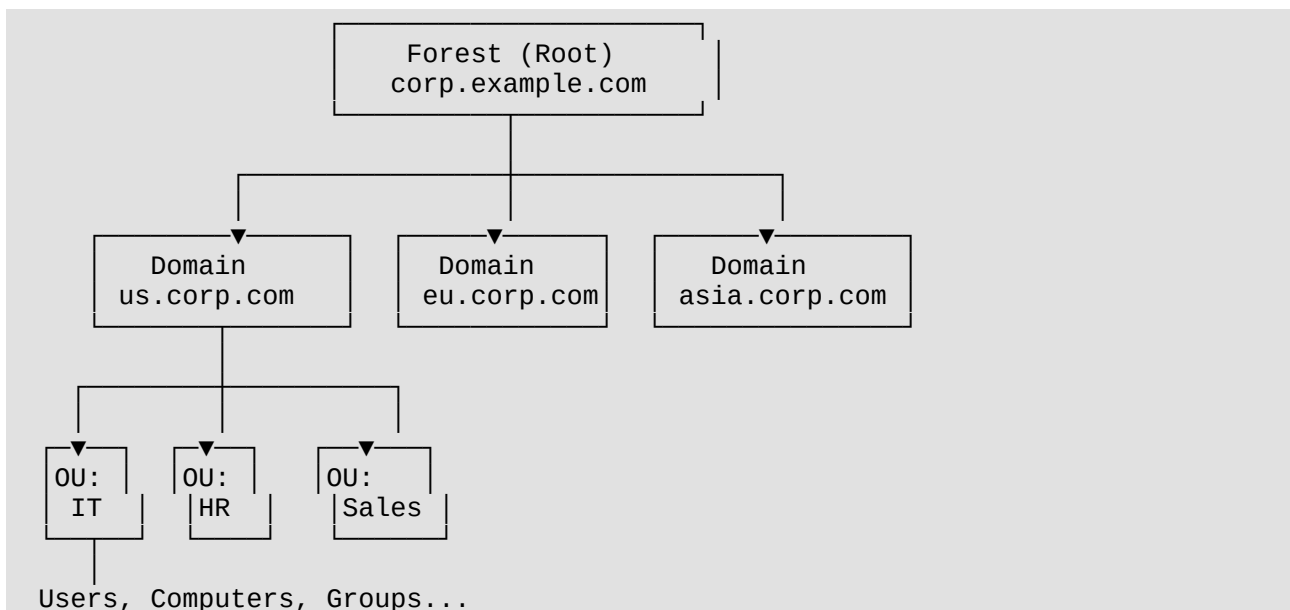
□ Topic 1: LDAP & SMB Enumeration — Full Deep Dive

Part A: Conceptual Foundation

What is Active Directory?

Active Directory (AD) is Microsoft's **directory service** — think of it as a massive phonebook/database that stores everything about an organization's network:

- **Users** (employees, service accounts)
- **Computers** (workstations, servers)
- **Groups** (who belongs where)
- **Policies** (rules applied to users/computers)
- **Organizational Units (OUs)** — logical containers to organize the above



Key AD Components

Component	What It Is	Analogy
Forest	Topmost container, collection of domains	The entire company
Domain	A logical group of objects sharing a database	A branch office
Domain Controller (DC)	Server that runs AD, handles authentication	The security guard with the master list
Organizational Unit (OU)	Container within a domain for organizing objects	A department folder

LDAP Bind — Authentication

Before you can search AD, you need to **bind** (authenticate):

Bind Type	What It Means	Pentest Use
Anonymous Bind	No credentials at all	First thing to test — often misconfigured to allow this
Null Bind	Empty username and password	Similar to anonymous — sometimes treated differently
Simple Bind	Username + password in plaintext	Used when you have credentials
SASL Bind	Secure authentication (Kerberos, NTLM)	Used by tools like nxc

[!IMPORTANT] **Anonymous/Null binds** are the first thing to test in an AD pentest. If the DC allows them, you can extract the entire directory without any credentials. This is a **misconfiguration** — modern AD defaults to blocking anonymous binds, but many environments still allow them.

LDAP Search — The Three Parameters

Every LDAP search needs three things:

Parameter	Meaning	Example
Base DN	Where to start searching	DC=corp, DC=example, DC=com
Scope	How deep to search	base, one, sub
Filter	What to look for	(objectClass=user)

Search Scopes Explained

```
DC=corp, DC=example, DC=com      ← BASE (only this node)
├── OU=IT                          ← ONE (only direct children)
│   ├── CN=Alice                  ← SUB (this + ALL descendants)
│   ├── CN=Bob
│   └── OU=Developers
│       ├── CN=Charlie
│       └── CN=Dave
├── OU=HR                          ← ONE
│   └── CN=Eve
└── OU=Sales                       ← ONE
    └── CN=Frank                  ←
```

- **base** — Only the node you specified (just the root)
- **one** — Only direct children (OU=IT, OU=HR, OU=Sales)
- **sub** — Everything below it (all users, all sub-OU's, everything)

LDAP Filters — The Query Language

Filters use a prefix notation with parentheses:

Simple:

```
(objectClass=user)           → Find all users
(sAMAccountName=admin)       → Find user named "admin"
(objectClass=computer)       → Find all computers
(objectClass=group)          → Find all groups
```

AND (&):

```
(&(objectClass=user)(!(userAccountControl:1.2.840.113556.1.4.803:=2)))
→ Find all ENABLED users (not disabled)
```

OR (|):

```
(|(sAMAccountName=admin)(sAMAccountName=administrator))
→ Find admin OR administrator
```

NOT (!):

```
(!(objectClass=computer))
→ Find everything that is NOT a computer
```

Wildcards:

```
(sAMAccountName=svc_*)
→ Find all accounts starting with "svc_"
```

Key LDAP Attributes to Know

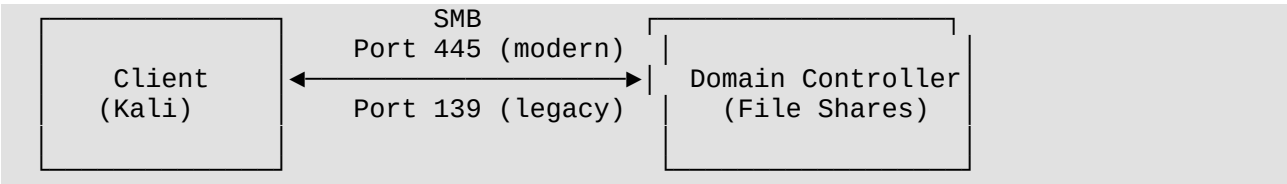
Attribute	What It Contains	Why It Matters
sAMAccountName	The login username	Used to build user lists for attacks
userPrincipalName	user@domain.com format	Alternative username format
memberOf	Groups the user belongs to	Shows privilege level
servicePrincipalName	SPN for service accounts	Kerberoasting targets
userAccountControl	Account flags (disabled, no pre-auth, etc.)	AS-REP Roasting targets (flag 4194304)
description	Freetext description	Admins sometimes put passwords here!
adminCount	Set to 1 for admin accounts	Quick way to find privileged accounts
pwdLastSet	When password was last changed	Old passwords = weak passwords
lastLogon	Last login timestamp	Inactive accounts = easy targets
distinguishedName	Full DN path	Shows where in the hierarchy they sit

What is SMB?

The Concept

SMB (Server Message Block) is a network file sharing protocol used by Windows. In an AD environment, SMB is used to:

- **Share files** (network drives, SYSVOL, NETLOGON)
- **Remote administration** (PsExec, WMI)
- **Authentication** (SMB uses NTLM or Kerberos)



- **Port 445** — Direct SMB over TCP (modern, most common)
- **Port 139** — SMB over NetBIOS (legacy, sometimes still seen)

SMB Authentication Flow

```
sequenceDiagram
    participant C as Client
    participant S as Server (DC)

    C->>S: 1. Negotiate Protocol (SMBv1/v2/v3?)
    S->>C: 2. Protocol Selected
    C->>S: 3. Session Setup (NTLM/Kerberos auth)
    S->>C: 4. Authentication Result
    C->>S: 5. Tree Connect (access a share)
    S->>C: 6. Share Access Granted
    C->>S: 7. File Operations (list, read, write)
```

SMB Authentication Types

Type	How It Works	Security Level
Null Session	No credentials	Weakest — should be disabled
Guest Session	Built-in guest account	Weak — often disabled
NTLM Auth	Challenge-response with password hash	Standard for workgroup
Kerberos Auth	Ticket-based via DC	Strongest — default in AD

Important Default Shares

Share Name	Path on DC	Purpose
SYSVOL	C:\Windows\SYSVOL	Group Policy distribution (readable by all domain users)
NETLOGON	C:\Windows\SYSVOL\...	Login scripts (readable by all)

Share Name	Path on DC	Purpose
	\Scripts	domain users)
C\$	C:\	Admin share (admin access only)
ADMIN\$	C:\Windows	Remote admin (admin access only)
IPC\$	N/A	Inter-process communication (used for null sessions)

[!NOTE] SYSVOL and NETLOGON are **readable by ALL authenticated domain users** by default. This is by design — but it means any domain user can browse them for sensitive data.

How LDAP and SMB Work Together in AD

```
graph LR
    A["Pentester"] -->|"LDAP (389/636)"| B["Domain Controller"]
    A -->|"SMB (445)"| B
    A -->|"Kerberos (88)"| B

    B -->|"LDAP: Returns users, groups, OUs, SPNs"| A
    B -->|"SMB: Returns shares, files, policies"| A
    B -->|"Kerberos: Returns tickets (TGT/TGS)"| A

    style A fill:#e74c3c,color:#fff
    style B fill:#3498db,color:#fff
```

In a pentest:

1. **LDAP** = Enumerate **who** exists (users, groups, service accounts)
2. **SMB** = Enumerate **what** exists (shares, files, policies, scripts)
3. **Kerberos** = Exploit **how** they authenticate (tickets → cracking)

Part B: Practical Enumeration

Step 1: Initial Discovery

Before anything, confirm the DC is running AD services:

```
# Scan for AD-related ports
nmap -p 53,88,135,139,389,445,464,636,3268,3269 DC_IP

# What each port tells you:
# 53   = DNS (DC is usually the DNS server)
# 88   = Kerberos (confirms it's a DC)
# 135  = RPC
# 139  = NetBIOS/SMB (legacy)
```

```
# 389 = LDAP
# 445 = SMB
# 464 = Kerberos password change
# 636 = LDAPS (LDAP over SSL)
# 3268 = Global Catalog
# 3269 = Global Catalog SSL
```

Step 2: LDAP Enumeration

```
# -----
# 2a. Get the domain naming context (domain name)
# -----
ldapsearch -x -H ldap://DC_IP -b "" -s base namingcontexts

# Output example:
#   namingContexts: DC=corp,DC=example,DC=com      ← Domain DN
#   namingContexts: CN=Configuration,DC=corp,...   ← Config
#   namingContexts: CN=Schema,CN=Configuration,... ← Schema
# -----
# 2b. Test anonymous bind – dump everything
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com"

# -----
# 2c. Extract all usernames
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(objectClass=user)" sAMAccountName | grep sAMAccountName

# -----
# 2d. Find users with descriptions (might contain passwords!)
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(objectClass=user)" sAMAccountName description | grep -A1 sAMAccountName

# -----
# 2e. Find service accounts (have SPNs → Kerberoasting targets)
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(servicePrincipalName=*)" sAMAccountName servicePrincipalName

# -----
# 2f. Find accounts with no pre-auth (AS-REP Roasting targets)
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(&(objectClass=user)(userAccountControl:1.2.840.113556.1.4.803:=4194304))" \
  sAMAccountName

# -----
# 2g. Find all groups
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(objectClass=group)" cn

# -----
# 2h. Find Domain Admins members
# -----
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \
  "(&(objectClass=group)(cn=Domain Admins))" member

# -----
# 2i. Find all computers
```

```
# -----  
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \  
"(objectClass=computer)" cn operatingSystem
```

Step 3: SMB Enumeration

```
# -----  
# 3a. Test null session / anonymous access  
# -----  
nxc smb DC_IP -u '' -p ''  
nxc smb DC_IP -u '' -p '' --shares  
nxc smb DC_IP -u 'guest' -p '' --shares  
  
# -----  
# 3b. List shares with credentials  
# -----  
nxc smb DC_IP -u 'user' -p 'password' --shares  
  
# -----  
# 3c. Enumerate users via SMB  
# -----  
nxc smb DC_IP -u 'user' -p 'password' --users  
nxc smb DC_IP -u 'user' -p 'password' --groups  
  
# -----  
# 3d. Connect to a share manually  
# -----  
smbclient //DC_IP/SYSVOL -U 'domain/user%password'  
smbclient //DC_IP/NETLOGON -U 'domain/user%password'  
  
# Inside smbclient:  
#   ls                → list files  
#   cd dirname        → change directory  
#   get filename      → download file  
#   recurse ON        → enable recursive operations  
#   prompt OFF        → disable confirmation prompts  
#   mget *            → download everything  
  
# -----  
# 3e. Spider/crawl shares for interesting files  
# -----  
nxc smb DC_IP -u 'user' -p 'password' --spider SYSVOL --regex "password|  
credential|secret"  
  
# -----  
# 3f. All-in-one enumeration  
# -----  
enum4linux -a DC_IP
```

Step 4: Format the User List

After extracting usernames, format them for attack tools:

```
# Raw ldapsearch output might look like:  
#   SAMAccountName: administrator  
#   SAMAccountName: john.smith  
#   SAMAccountName: svc_sql  
#   SAMAccountName: support  
  
# Clean it into a simple list:  
ldapsearch -x -H ldap://DC_IP -b "DC=corp,DC=example,DC=com" \  
"(objectClass=user)" SAMAccountName | grep SAMAccountName | \  
awk '{print $2}'
```



```
awk '{print $2}' > users.txt

# Result (users.txt):
# administrator
# john.smith
# svc_sql
# support

# This list feeds directly into:
#   → GetNPUsers (AS-REP Roasting)
#   → GetUserSPNs (Kerberoasting)
#   → Password spraying
```

Part C: What Can Go Wrong (Defenses You'll Encounter)

Defense	What It Blocks	Workaround
Anonymous bind disabled	No LDAP without creds	Need at least one valid account
SMB signing required	Relay attacks	Direct auth still works
Null sessions blocked	No anonymous share listing	Need creds for enumeration
LDAPS only (636)	Plaintext LDAP blocked	Use <code>ldaps://</code> instead of <code>ldap://</code>
Account lockout policy	Too many failed logins	Be careful with spraying

Part D: Key Concepts for Exam

[!IMPORTANT] **Must-know concepts for the exam:**

1. What is a Naming Context?

The root DN of the domain. Everything in LDAP is referenced relative to this. Example:
`DC=corp, DC=example, DC=com = corp.example.com`

2. What is an SPN (Service Principal Name)?

A unique identifier for a service instance. When a service runs under a domain account with an SPN, that account becomes **Kerberoastable**. Example:
`MSSQLSvc/sqlserver.corp.com:1433`

3. What is userAccountControl?

A bitmask flag on user objects. The value 4194304 means "**Do not require Kerberos preauthentication**" → makes the account **AS-REP Roastable**.

4. Why is SYSVOL important?

It's readable by ALL domain users and contains Group Policies. Old GPPs stored encrypted passwords with a **publicly leaked AES key** → instant credential theft.

5. What is the difference between LDAP and SMB in enumeration?

- **LDAP** = Queries the directory database (users, groups, attributes)
 - **SMB** = Accesses file shares (SYSVOL, NETLOGON, custom shares)
 - Both are needed: LDAP gives you **who**, SMB gives you **what files**
-

□ Self-Check Questions

Test yourself before moving to Topic 2:

1. What port does LDAP use? What about LDAPS?
 2. What is a Distinguished Name? Give an example.
 3. What three things does every LDAP search need?
 4. What is the difference between **base**, **one**, and **sub** scope?
 5. What is an anonymous bind and why is it dangerous?
 6. Name three default shares on a Domain Controller.
 7. Which share contains Group Policy files?
 8. What LDAP attribute reveals Kerberoasting targets?
 9. What `userAccountControl` flag indicates AS-REP Roasting vulnerability?
 10. What command extracts usernames via LDAP?
 1. **389** (LDAP), **636** (LDAPS)
 2. A unique path to an object: `CN=John,OU=IT,DC=corp,DC=com`
 3. **Base DN, Scope, Filter**
 4. **base** = only the node itself, **one** = direct children only, **sub** = everything recursively
 5. Connecting to LDAP without credentials — exposes the entire directory if allowed
 6. SYSVOL, NETLOGON, IPC\$ (also C\$, ADMIN\$)
 7. **SYSVOL**
 8. `servicePrincipalName` (SPN)
 9. `4194304` (DONT_REQ_PREAUTH)
 10. `ldapsearch -x -H ldap://DC_IP -b "DC=domain,DC=com" "(objectClass=user)" sAMAccountName`
-

Next up → Topic 2: Share Hunting & GPP Credential Harvesting Say "next" when you're ready!